AUDITORIA TECNICA E INFORME

GRC Corporativo

PARTE 1

PROPUESTA DE AUDITORÍA TÉCNICA

XYZ Corp · SecureAudit Solutions S.L.

Versión 1.0 · Julio 2024 · CONFIDENCIAL

1. Introducción

El presente documento constituye la propuesta formal de auditoría técnica elaborada por SecureAudit Solutions S.L. (en adelante, EL PROVEEDOR) a solicitud de XYZ Corp (en adelante, EL CLIENTE), con domicilio social en Calle Gran Vía 45, 28013 Madrid, y CIF B-87654321.

XYZ Corp es una empresa dedicada al comercio electrónico de material informático, con presencia online a través de su plataforma www.xyz.com y con infraestructura tecnológica distribuida entre sus instalaciones en Madrid (sede central) y sistemas en cloud. La nueva dirección, incorporada en enero de 2024, ha identificado la ciberseguridad como pilar estratégico fundamental para garantizar la confianza de sus clientes y la continuidad del negocio.

En este contexto, EL CLIENTE ha solicitado la realización de una auditoría técnica integral que cubra los principales vectores de ataque identificados: infraestructura de red, aplicaciones web, redes Wi-Fi y aplicaciones móviles.

2. Propósito de la Auditoría

El propósito principal es evaluar de forma proactiva el nivel de exposición de los sistemas de información de XYZ Corp ante posibles atacantes externos e internos, identificando vulnerabilidades y debilidades antes de que puedan ser explotadas maliciosamente. Esta iniciativa responde a los siguientes motivadores:

- Cumplimiento normativo: garantizar la adecuación a los requisitos del RGPD (UE 2016/679) en materia de seguridad del tratamiento de datos personales de clientes.

- Protección de activos críticos: salvaguardar la plataforma de e-commerce ante ataques con potencial impacto económico, de datos o reputacional.
- Mejora continua: establecer una línea base (baseline) del estado de seguridad actual que sirva de referencia para futuras auditorías.
- Requisito contractual: clientes corporativos de XYZ Corp exigen evidencias de auditorías de seguridad periódicas como condición contractual.

3. Objetivo de la Auditoría

El objetivo fundamental es la realización de cuatro auditorías técnicas especializadas, con la generación de los siguientes entregables:

- Informe técnico detallado: vulnerabilidades, evidencias, clasificación CVSS y propuestas de remediación. Orientado al equipo de IT de XYZ Corp.
- Informe ejecutivo: resumen de hallazgos principales traducidos a impacto de negocio y plan de acción priorizado. Orientado a la Dirección General.
- Presentación de resultados (readout): sesión con el equipo técnico y dirección para resolver dudas y acordar el plan de remediación.

4. Alcance de la Auditoría

4.1 Auditoría de Infraestructura de Red

- Rango de red interna: 192.168.1.0/24 (sede Madrid, aprox. 80 hosts activos)
- IPs públicas: 123.123.123.123 (servidor web / DMZ) y 123.123.123.124 (VPN corporativa)
- Tipo: Caja gris. Se facilitan rangos de red y diagrama de arquitectura de alto nivel.
- Modalidad: Remota (acceso mediante VPN provisionada por XYZ Corp)

4.2 Auditoría de Aplicaciones Web

- Aplicación principal: https://www.xyz.com (tienda online, PHP/Laravel)

- Aplicación interna: https://intranet.xyz.local/horario (control horario, solo acceso LAN)
- Tipo: Caja gris. Se facilitan credenciales de usuario de prueba y documentación funcional.
- Modalidad: Remota

4.3 Auditoría de Redes Wi-Fi

- Red corporativa: 'XYZ-Corp' (WPA2-Personal, empleados)
- Red de invitados: 'XYZ-Guest' (WPA2-Personal, clientes y visitas)
- Tipo: Caja negra. Sin información previa.
- Modalidad: Presencial en sede de Madrid (visita concertada)

4.4 Auditoría de Dispositivos Móviles

- Aplicación Android: 'XYZ App' v3.1.2 (Google Play, catálogo y compras)
- Análisis estático de la APK + análisis dinámico sobre dispositivo/emulador facilitado por el cliente
- Tipo: Caja gris. Se facilita APK y credenciales de usuario de prueba.
- Modalidad: Remota

4.5 Exclusiones del Alcance

- Infraestructura cloud de terceros (AWS, proveedor de hosting)
- Dispositivos de usuario final (PCs, portátiles) salvo los explícitamente incluidos
- Pruebas de denegación de servicio (DoS/DDoS) intencionadas
- Ingeniería social y phishing a empleados

5. Metodología

5.1 Infraestructura de Red – OSSTMM v3

Metodología OSSTMM (Open Source Security Testing Methodology Manual) v3. Herramientas: nmap, Tenable Nessus, OpenVAS, Metasploit Framework, Wireshark, TCPdump.

5.2 Aplicaciones Web – OWASP Testing Guide v4.2

OWASP Testing Guide v4.2 con especial atención al OWASP Top 10 2021. Herramientas: Burp Suite Pro, OWASP ZAP, sqlmap, nikto.

5.3 Redes Wi-Fi – OWISAM

Framework OWISAM diseñado específicamente para auditoría de redes inalámbricas. Herramientas: aircrack-ng suite, airodump-ng, Reaver, Hashcat, inSSIDer, Kismet.

5.4 Dispositivos Móviles – OWASP MSTG / MASVS

OWASP Mobile Security Testing Guide (MSTG) y Mobile Application Security Verification Standard (MASVS). Herramientas: MobSF, SonarQube, Genymotion, Frida.

6. Plan de Recogida y Análisis de Datos

El personal técnico asignado cuenta con certificaciones vigentes: CEH, OSCP, eJPT y CSX. Los trabajos se realizarán en paralelo durante 8 semanas desde la reunión de arranque. Las evidencias se almacenarán en repositorio cifrado y serán destruidas en 30 días tras la entrega del informe final, conforme al NDA.

Para el inicio, XYZ Corp deberá facilitar: VPN de acceso al rango interno, dispositivo Android de prueba (o autorización de emulador), y un interlocutor técnico disponible durante todo el proyecto.

7. Organización y Recursos

Equipo asignado por EL PROVEEDOR:

- Director de Proyecto: coordinación general, comunicación con cliente y supervisión de entregables.
- Analista de Red (Senior): auditoría de infraestructura de red y Wi-Fi.
- Analista de Aplicaciones Web (Senior): auditoría de aplicaciones web.

- Analista de Móviles (Mid): auditoría de la aplicación Android.

Requisitos de EL CLIENTE:

- Provisionar VPN de acceso al rango interno en los primeros 5 días hábiles tras la reunión de arranque.
- Facilitar dispositivo Android de prueba o autorizar el uso de emulador Genymotion.
- Coordinar visita presencial para el análisis Wi-Fi.
- Designar interlocutor técnico con disponibilidad garantizada durante todo el proyecto.

8. Comunicaciones

Canal principal: Microsoft Teams (canal compartido). Canal formal: correo electrónico para entregables y comunicaciones con trazabilidad. Urgencias: teléfono del Director de Proyecto. Reuniones de seguimiento: semanales, lunes 10:00h (30 min). Ante un hallazgo crítico, notificación al interlocutor técnico en un máximo de 4 horas desde su confirmación.

9. Plazos y Costes

Servicio	Duración	Modalidad	Coste estimado
Auditoría de red	2 semanas	Remota	3.200 €
Auditoría web	2 semanas	Remota	2.800 €
Auditoría Wi-Fi	1 semana	Presencial	1.500 €
Auditoría móvil	2 semanas	Remota	2.500 €
Gestión / Informes	1 semana	Remota	1.000 €
TOTAL	8 semanas		**11.000 € (+ IVA)**

* Precios orientativos sujetos a la firma del contrato. Se incluye sesión de readout final sin coste adicional.

10. Riesgos Asociados al Proyecto

Riesgo	Probabilidad	Mitigación
Indisponibilidad de VPN de acceso	Media	Contacto técnico con resolución garantizada en < 24h
Interrupción involuntaria de servicio	Baja	Pruebas en ventanas de mantenimiento; carta de autorización firmada
Bloqueo de IPs por IDS/IPS	Media	Whitelisting de IPs del equipo auditor antes del inicio
Falta de interlocutor técnico	Media	SLA de respuesta máxima de 1 día hábil en contrato
Ampliación del alcance	Baja	Addendum al contrato con ajuste de plazos y costes

ANEXO A – ACUERDO DE CONFIDENCIALIDAD (NDA)

En Madrid, a 1 de julio de 2024

De una parte, XYZ Corp (en adelante, CLIENTE), con C.I.F. B-87654321 y domicilio social en Calle Gran Vía 45, 28013 Madrid, representada por D. Carlos Martínez López, Director General.

De otra parte, SecureAudit Solutions S.L. (en adelante, PROVEEDOR), con C.I.F. B-12345678 y domicilio social en Calle Serrano 100, 28006 Madrid, representada por D.ª Ana García Fernández, CEO y Socia Directora.

Ambas partes acuerdan lo siguiente:

I. CLIENTE es una organización dedicada al comercio electrónico de material informático y es responsable de la información generada y gestionada en su actividad, incluyendo datos personales de clientes conforme al RGPD.

II. PROVEEDOR es una organización dedicada a la prestación de servicios de ciberseguridad y proporciona servicios de auditoría técnica de seguridad informática a CLIENTE.

III. PROVEEDOR durante la prestación de servicios puede recibir información confidencial de CLIENTE, incluyendo: arquitectura de sistemas, código fuente, bases de datos, datos de clientes, credenciales, vulnerabilidades detectadas y planes estratégicos.

IV. PROVEEDOR usará la información únicamente en el ámbito de los servicios de auditoría técnica y trasladará el deber de confidencialidad a todo su personal mediante acuerdos específicos.

V. Exclusiones: (a) información pública en el momento de su cesión; (b) información conocida por PROVEEDOR previamente; (c) información cuya divulgación sea exigida por ley o requerimiento judicial.

VI. La propiedad intelectual de los informes de auditoría generados pertenece a CLIENTE.

VII. Ante cualquier revelación no autorizada, PROVEEDOR indemnizará a CLIENTE por los daños y perjuicios ocasionados.

VIII. PROVEEDOR destruirá de forma segura toda la información confidencial en un plazo máximo de 30 días tras la entrega del informe final, acreditándolo mediante certificado de destrucción si CLIENTE así lo solicita.

IX. Las partes cumplirán el RGPD (UE 2016/679) y la LOPDGDD (LO 3/2018). PROVEEDOR actuará como encargado del tratamiento, suscribiéndose el correspondiente contrato conforme al art. 28 RGPD.

X. Este acuerdo tendrá validez indefinida desde su firma, incluso tras la finalización de la relación contractual.

XI. Ante cualquier disputa, ambas partes se someten a los Juzgados y Tribunales de Madrid, renunciando a su fuero propio.

En nombre de CLIENTE	**En nombre de PROVEEDOR**
_____	_____
D. Carlos Martínez López	D.ª Ana García Fernández
Director General – XYZ Corp	CEO – SecureAudit Solutions S.L.

ANEXO B – CARTA DE AUTORIZACIÓN

XYZ Corp, con domicilio en Calle Gran Vía 45, 28013 Madrid y CIF B-87654321, inscrita en el Registro Mercantil de Madrid, autoriza a:

SecureAudit Solutions S.L. a conducir una auditoría de seguridad de sus sistemas de información y comunicaciones, cuyo alcance se circunscribe a realizar pruebas de diversa índole para verificar el grado de protección en materia de ciberseguridad de XYZ Corp, conforme a los sistemas detallados en la Parte 1 del presente documento.

Esta revisión se realizará entre el 1 de julio de 2024 y el 26 de agosto de 2024.

Excepto indicación expresa de XYZ Corp, SecureAudit Solutions S.L. NO intentará provocar que los servidores queden fuera de servicio de manera directa o indirecta. Sin embargo, y dada la naturaleza de las pruebas, tales circunstancias podrían darse de forma involuntaria a pesar de la debida diligencia profesional. SECUREAUDIT SOLUTIONS S.L. DECLINA CUALQUIER TIPO DE RESPONSABILIDAD POR TODOS LOS DAÑOS QUE PUDIERAN DERIVARSE DIRECTA O INDIRECTAMENTE DE LA REALIZACIÓN DE LA AUDITORÍA.

Se recomienda a XYZ Corp adoptar las siguientes medidas antes del inicio:

- Realizar backups completos y verificados de todos los sistemas incluidos en el alcance.
- Incrementar temporalmente la monitorización de los sistemas durante el período de auditoría.
- Alertar al equipo de soporte técnico interno y garantizar su disponibilidad reforzada.
- Disponer de un procedimiento de rollback operativo para restauración rápida de servicios.

XYZ Corp declara haber leído y estar conforme con todo lo expresado en el presente documento.

Nombre: D. Carlos Martínez López
Cargo: Director General – XYZ Corp
Lugar y fecha: Madrid, 1 de julio de 2024
Firma y sello: _____

PARTE 2

INFORME DE AUDITORÍA TÉCNICA

XYZ Corp · SecureAudit Solutions S.L.

Versión 1.0 · Septiembre 2024 · CONFIDENCIAL

1. Introducción

1.1 Antecedentes

El presente informe recoge los resultados de la auditoría técnica de seguridad realizada por SecureAudit Solutions S.L. sobre los sistemas de información de XYZ Corp, en el marco del contrato de servicios firmado el 1 de julio de 2024. Los trabajos se han llevado a cabo entre el 1 de julio y el 26 de agosto de 2024, principalmente de forma remota, a excepción del análisis de redes Wi-Fi, realizado de forma presencial el 28 de julio de 2024 en la sede de Madrid.

1.2 Objetivo

El objetivo principal ha sido detectar los posibles riesgos de seguridad que afectan a los sistemas de XYZ Corp dentro del alcance definido, evaluar su explotabilidad real y traducir el impacto técnico a términos de negocio para facilitar la priorización de las acciones de remediación.

1.3 Alcance

- Infraestructura de red: rango interno 192.168.1.0/24 (~80 hosts activos) e IPs públicas 123.123.123.123 y 123.123.123.124.
- Aplicaciones web: www.xyz.com (tienda online PHP/Laravel) e intranet.xyz.local/horario (control horario).
- Redes Wi-Fi: red corporativa 'XYZ-Corp' y red de invitados 'XYZ-Guest' (ambas WPA2-Personal).
- Aplicación móvil Android: 'XYZ App' v3.1.2 – análisis estático y dinámico.

2. Resumen Ejecutivo

Los trabajos de auditoría han revelado que XYZ Corp ha implementado algunos controles básicos de seguridad (HTTPS, firewall perimetral, separación de redes Wi-Fi), pero se han identificado vulnerabilidades de gravedad crítica y alta en todos los ámbitos auditados que requieren atención urgente.

El hallazgo más grave es la inyección SQL en la plataforma de e-commerce (H-03, CVSS 10.0), que ha permitido extraer la base de datos completa de 4.312 clientes. Este hallazgo supone un riesgo regulatorio inmediato bajo el RGPD (posible obligación de notificación a la AEPD en 72h). En segundo lugar, las credenciales de fábrica del firewall (H-01, CVSS 9.0) han comprometido la seguridad perimetral de toda la organización.

Hallazgo	Tipo de auditoría	Severidad	CVSS	Plazo solución
H-01 – Credenciales por defecto en firewall (CWE-521)...	Infraestructura de red	CRÍTICO	9.0	1 semana
H-02 – Sistemas operativos obsoletos sin soporte (CWE-1104)...	Infraestructura de red	MEDIO	6.5	6 meses
H-03 – Inyección SQL en búsqueda de producto (CWE-89)...	Aplicaciones web	CRÍTICO	10.0	1 semana (urgente)
H-04 – Insecure Direct Object Reference – IDOR (CWE-639)...	Aplicaciones web	MEDIO	6.0	2 semanas
H-05 – Handshake WPA2 crackeado – contraseña débil (OWISAM-AU-...	Redes Wi-Fi	ALTO	7.5	Inmediato + 3 meses (WPA2-Ent.)
H-06 – SSID genérico revela configuración de fábrica (OWISAM-C...	Redes Wi-Fi	BAJO	3.5	1 semana
H-07 – Permisos excesivos en aplicación Android (CWE-732)...	Dispositivos móviles	MEDIO	5.5	3 semanas
H-08 – Almacenamiento de contraseñas con MD5 sin salt (CWE-327...	Dispositivos móviles	MEDIO	5.0	2 semanas

3. Metodología

Se han seguido las metodologías descritas en la propuesta: OSSTMM v3 (red), OWASP Testing Guide v4.2 (web), OWISAM (Wi-Fi) y OWASP MSTG/MASVS (móvil). De forma transversal se ha utilizado la metodología EDR (Evidencia-Descripción-Recomendación), garantizando que toda vulnerabilidad reportada está respaldada por evidencia objetiva.

Las fases ejecutadas en todas las áreas han sido:

- Reconocimiento: identificación de tecnologías, servicios y vectores de ataque mediante OSINT y escaneo pasivo.
- Análisis de vulnerabilidades: identificación sistemática con herramientas automatizadas y revisión manual, con cribado de falsos positivos.
- Explotación controlada: intento de compromiso para confirmar explotabilidad real y cuantificar impacto efectivo.
- Post-explotación: análisis de movimientos laterales, escalada de privilegios y posibilidades de exfiltración de datos.

4. Desarrollo del Trabajo – Hallazgos

4.1 Auditoría de Infraestructura de Red

El análisis del rango interno 192.168.1.0/24 ha identificado 78 hosts activos. Se han detectado los siguientes hallazgos:

H-01 – CRÍTICO | Credenciales por defecto en firewall (CWE-521)	
Tipo de auditoría	Infraestructura de red
CVSS / Severidad	9.0 – CRÍTICO
Descripción	Las credenciales de acceso al firewall perimetral (Fortinet FortiGate 60F) son las de fábrica (admin/admin). El equipo auditor accedió con plenos privilegios al panel de administración, deshabilitó todas las reglas de filtrado y abrió paso a ataques adicionales contra la red interna. Impacto: compromiso total del perímetro.
Evidencia	Acceso verificado con credenciales admin/admin. Volcado de tabla de reglas desactivadas adjuntado como Evidencia E-01. 📷 **[Imagen: Captura del panel de administración FortiGate con acceso completo mediante credenciales admin/admin]**
Solución propuesta	Cambiar de inmediato las credenciales de todos los dispositivos de red (firewalls, switches, routers, APs) por contraseñas únicas de mínimo 12 caracteres. Implantar procedimiento de hardening obligatorio para nuevos dispositivos antes de su puesta en producción.
Tiempo estimado	1 semana

H-02 – MEDIO | Sistemas operativos obsoletos sin soporte (CWE-1104)	
Tipo de auditoría	Infraestructura de red
CVSS / Severidad	6.5 – MEDIO
Descripción	Se han identificado 4 equipos con Windows 7 y un servidor con Windows Server 2008 R2, sin soporte desde enero/julio de 2020. Aunque están parcheados contra exploits conocidos (EternalBlue, BlueKeep), la ausencia de parches futuros supone un riesgo creciente ante vulnerabilidades de día cero. CVSS Medio (6.5) al existir mitigaciones activas.
Evidencia	Salida del escáner Tenable Nessus (ID 20240728-INT-01) con 5 hosts SO fuera de soporte. Adjuntado como Evidencia E-02. 📷 **[Imagen: Informe Tenable Nessus – listado de 5 hosts con Windows 7 / Server 2008 R2 (EoL)]**

Solución propuesta	Planificar la migración a versiones actuales (Windows 10/11, Server 2022) en máximo 6 meses. Para equipos que no puedan migrarse, aplicar medidas compensatorias: aislamiento mediante VLAN, monitorización reforzada con SIEM y deshabilitación de servicios innecesarios.
Tiempo estimado	6 meses

4.2 Auditoría de Aplicaciones Web

El análisis ha cubierto la tienda online www.xyz.com y la aplicación de control horario de la intranet. Se han detectado los siguientes hallazgos:

H-03 – CRÍTICO | Inyección SQL en búsqueda de producto (CWE-89)	
Tipo de auditoría	Aplicaciones web
CVSS / Severidad	10.0 – CRÍTICO
Descripción	Se detectó inyección SQL en el parámetro 'id' de https://www.xyz.com/producto?id=X. Con la cadena ' OR 1=1-- se volcó la base de datos completa: 4.312 clientes con datos personales y contraseñas en MD5 sin salt. Impacto máximo (CVSS 10.0) por datos de pago expuestos y posible brecha RGPD.
Evidencia	Captura sqlmap con volcado de xyz_db (21 tablas). Hash del admin crackeado con hashcat en < 2 minutos. Adjuntado como Evidencia E-03. [Datos anonimizados según NDA] **📷 [Imagen: Salida sqlmap – volcado de tabla 'usuarios' con 4.312 registros y hashes MD5 expuestos]**
Solución propuesta	Sustituir urgentemente todas las consultas SQL dinámicas por consultas parametrizadas (prepared statements) o usar un ORM. Implementar WAF. Sustituir MD5 por bcrypt/Argon2 con salt. Evaluar notificación a la AEPD (obligación RGPD art. 33, plazo 72h).
Tiempo estimado	1 semana (urgente)

H-04 – MEDIO | Insecure Direct Object Reference – IDOR (CWE-639)	
Tipo de auditoría	Aplicaciones web
CVSS / Severidad	6.0 – MEDIO
Descripción	IDOR en la aplicación de control horario interna (intranet.xyz.local/horario?empleado=ID). Modificando el parámetro 'empleado' sin autenticación adicional es posible consultar y modificar registros de cualquier empleado. Solo desde red interna; CVSS Medio (6.0).

Evidencia	Prueba manual con Burp Suite modificando parámetro 'empleado' de 1042 a 1001 (Director de RRHH), obteniendo acceso completo a sus registros. Adjuntado como Evidencia E-04. 📷 **[Imagen: Captura Burp Suite – petición GET con parámetro 'empleado=1001' accediendo a datos del Director de RRHH sin autenticación adicional]**
Solución propuesta	Implementar control de autorización RBAC que valide en servidor que el usuario autenticado solo accede a sus propios registros, salvo rol con privilegios explícitos. Añadir logging de accesos a datos sensibles.
Tiempo estimado	2 semanas

4.3 Auditoría de Redes Wi-Fi

El análisis se realizó presencialmente el 28 de julio de 2024 en la sede de Madrid, cubriendo las redes corporativa y de invitados. Se han detectado los siguientes hallazgos:

H-05 – ALTO | Handshake WPA2 crackeado – contraseña débil (OWISAM-AU-004)	
Tipo de auditoría	Redes Wi-Fi
CVSS / Severidad	7.5 – ALTO
Descripción	Captura del handshake WPA2 con airodump-ng y ataque de diccionario con aircrack-ng permitió obtener las contraseñas de 'XYZ-Corp' y 'XYZ-Guest' en < 10 minutos. Ambas contenían el nombre de la empresa. Se ejecutó con éxito un ataque MitM capturando credenciales HTTP en texto plano. CVSS Alto (7.5).
Evidencia	Fichero .cap con handshake, log aircrack-ng con contraseña obtenida y captura de tráfico MitM con credenciales interceptadas. Adjuntado como Evidencia E-05. [Datos anonimizados] 📷 **[Imagen: Log aircrack-ng mostrando contraseña 'XYZ2022!' obtenida en 8 minutos 43 segundos mediante ataque de diccionario]**
Solución propuesta	Inmediato: cambiar contraseñas de todas las redes Wi-Fi por contraseñas aleatorias de mínimo 20 caracteres. Medio plazo: migrar red corporativa a WPA2-Enterprise con servidor RADIUS y autenticación por certificado. Segmentar red de invitados del entorno corporativo mediante VLAN.
Tiempo estimado	Inmediato + 3 meses (WPA2-Ent.)

H-06 – BAJO | SSID genérico revela configuración de fábrica (OWISAM-CF-001)	
Tipo de auditoría	Redes Wi-Fi
CVSS / Severidad	3.5 – BAJO

Descripción	El AP de recepción emite el SSID 'NETGEAR_EXT_2G', formato genérico que sugiere configuración de fábrica. Aunque la contraseña no era la de defecto, puede orientar a un atacante hacia otros parámetros débiles del dispositivo. CVSS Bajo (3.5).
Evidencia	Escaneo con inSSIDer detectando SSID 'NETGEAR_EXT_2G' asociado a MAC 9C:3D:CF:XX:XX:XX. Adjuntado como Evidencia E-06. **[Imagen: Captura inSSIDer – SSID 'NETGEAR_EXT_2G' identificado con señal -58 dBm en zona de recepción]**
Solución propuesta	Cambiar el SSID a un nombre que no revele fabricante, modelo ni ubicación. Verificar y actualizar el firmware del dispositivo. Cambiar la contraseña de administración del panel web.
Tiempo estimado	1 semana

4.4 Auditoría de Dispositivos Móviles

El análisis de 'XYZ App' v3.1.2 ha combinado análisis estático de la APK y análisis dinámico sobre emulador Genymotion. Se han detectado los siguientes hallazgos:

H-07 – MEDIO | Permisos excesivos en aplicación Android (CWE-732)	
Tipo de auditoría	Dispositivos móviles
CVSS / Severidad	5.5 – MEDIO
Descripción	Análisis estático de la APK 'XYZ App' v3.1.2 con MobSF reveló 14 permisos en el AndroidManifest.xml, de los cuales 5 son innecesarios: READ_CONTACTS, ACCESS_FINE_LOCATION, READ_CALL_LOG, CAMERA y READ_EXTERNAL_STORAGE. La app es un catálogo con login para el que ninguno es requerido. Riesgo de privacidad y posible incumplimiento del RGPD (minimización de datos). CVSS Medio (5.5).
Evidencia	Extracto del AndroidManifest.xml con los 14 permisos declarados y análisis MobSF con 5 permisos peligrosos innecesarios. Adjuntado como Evidencia E-07. **[Imagen: Captura MobSF – análisis estático de AndroidManifest.xml con 5 permisos peligrosos innecesarios marcados en rojo]**
Solución propuesta	Auditar el AndroidManifest.xml eliminando todos los permisos no estrictamente necesarios. Adoptar principio de mínimo privilegio. Para permisos futuros, solicitarlos en runtime con explicación al usuario. Revisar cumplimiento RGPD.
Tiempo estimado	3 semanas

H-08 – MEDIO | Almacenamiento de contraseñas con MD5 sin salt (CWE-327)	
Tipo de auditoría	Dispositivos móviles

CVSS / Severidad	5.0 – MEDIO
Descripción	Análisis dinámico con Genymotion y Frida detectó que la app almacena credenciales en SharedPreferences hasheadas con MD5 sin salt. MD5 es criptográficamente inseguro desde hace más de una década. Un atacante con acceso físico al dispositivo podría crackear los hashes casi instantáneamente con tablas rainbow. CVSS Medio (5.0).
Evidencia	Volcado de com.xyz.app_preferences.xml con el campo 'password_hash' en MD5. Hash crackeado con hashcat en 3 segundos usando rockyou.txt. Adjuntado como Evidencia E-08. 📷 **[Imagen: Volcado SharedPreferences – campo 'password_hash' con hash MD5 en texto plano; hash crackeado con hashcat en 3 segundos]**
Solución propuesta	Sustituir MD5 por bcrypt, scrypt o Argon2 con salt único por usuario. Valorar si es necesario almacenar credenciales localmente o usar tokens OAuth2 de vida limitada. Implementar cifrado del almacenamiento local con Android Keystore.
Tiempo estimado	2 semanas

5. Evaluación de Riesgos

La siguiente tabla resume la distribución de hallazgos por nivel de riesgo, considerando la puntuación CVSS base y el contexto de negocio de XYZ Corp:

Nivel	Nº hallazgos	IDs	Impacto de negocio
CRÍTICO	2	H-01, H-03	Compromiso total del perímetro y fuga masiva de datos de clientes. Riesgo regulatorio RGPD.
ALTO	1	H-05	Acceso a red corporativa e interceptación de tráfico interno (MitM).
MEDIO	4	H-02, H-04, H-07, H-08	Exposición de datos internos, riesgo de privacidad y uso de criptografía débil.
BAJO	1	H-06	Información que facilita reconocimiento por parte de un atacante.

6. Conclusiones

Los resultados de la auditoría revelan una situación de riesgo significativa en los sistemas de XYZ Corp. Si bien la organización ha comenzado a implementar controles básicos, existen vulnerabilidades críticas que de ser explotadas por un atacante real podrían tener consecuencias devastadoras:

- La inyección SQL (H-03, CVSS 10.0) ha permitido extraer la base de datos completa con datos personales de más de 4.000 clientes. Esto constituye potencialmente una brecha de seguridad bajo el RGPD con obligación de notificación a la AEPD en 72 horas y posibles sanciones de hasta el 4% de la facturación anual global.
- Las credenciales por defecto del firewall (H-01, CVSS 9.0) han comprometido la seguridad de todo el perímetro de la organización. Un atacante con acceso a este dispositivo tendría control total sobre el tráfico de red.
- El crackeo de las contraseñas Wi-Fi (H-05, CVSS 7.5) ha expuesto el tráfico interno de la red corporativa a un potencial atacante en las proximidades físicas de las instalaciones.

Los hallazgos de severidad media (H-02, H-04, H-07, H-08) reflejan carencias en las prácticas de desarrollo seguro y gestión de activos que deben corregirse para elevar el nivel de madurez de seguridad. Se recomienda planificar una segunda fase de auditoría que incluya la infraestructura cloud y los endpoints de usuario.

7. Plan de Acción

Se recomienda abordar los hallazgos en el siguiente orden de prioridad, considerando la severidad CVSS, el impacto de negocio y el esfuerzo estimado de remediación:

ID	Acción correctiva	Prioridad	Esfuerzo	Plazo
H-01	Cambiar credenciales y aplicar hardening en dispositivos de red	CRÍTICO	Bajo	1 semana
H-02	Migrar SO obsoletos o aislar con VLAN y medidas compensatorias	MEDIO	Alto	6 meses
H-03	Consultas parametrizadas, WAF y revisión completa del código	CRÍTICO	Bajo	1 semana (urgente)
H-04	Implementar control de autorización RBAC en aplicación de RRHH	MEDIO	Bajo	2 semanas
H-05	Contraseña robusta inmediata + migración a WPA2-Enterprise con RADIUS	ALTO	Medio	Inmediato + 3 meses (WPA2-Ent.)
H-06	Renombrar SSID y verificar hardening completo del AP	BAJO	Bajo	1 semana
H-07	Eliminar permisos innecesarios del AndroidManifest y revisión RGPD	MEDIO	Bajo	3 semanas
H-08	Migrar a bcrypt/Argon2 con salt y usar Android Keystore	MEDIO	Bajo	2 semanas

7.1 Matriz Esfuerzo vs. Impacto – Quick Wins

Para facilitar la priorización ejecutiva, se presenta la siguiente matriz que clasifica cada hallazgo según el esfuerzo de remediación y el impacto de negocio esperado. Las acciones marcadas como Quick Win son las que ofrecen mayor reducción de riesgo con menor inversión y deben abordarse en primer lugar:

ID	Acción	Esfuerzo	Impacto	Tipo
H-01	Cambiar credenciales del firewall	Bajo	Crítico	Quick Win ✓

H-03	Aplicar consultas parametrizadas (SQL)	Bajo	Crítico	**Quick Win ✓**
H-04	Control RBAC en aplicación de RRHH	Bajo	Medio	**Quick Win ✓**
H-06	Renombrar SSID y hardening del AP	Bajo	Bajo	**Quick Win ✓**
H-07	Eliminar permisos excesivos en APK	Bajo	Medio	**Quick Win ✓**
H-08	Migrar contraseñas a bcrypt/Argon2	Bajo	Medio	**Quick Win ✓**
H-05	Migrar a WPA2-Enterprise + RADIUS	Alto	Alto	**Proyecto**
H-02	Migrar SO obsoletos (Windows 7)	Alto	Medio	**Proyecto**

Quick Win: acción de bajo esfuerzo (< 1 semana de trabajo técnico) con impacto medio o crítico en la reducción del riesgo.

Recomendaciones adicionales para la implementación del plan:

- Designar un responsable interno de cada acción correctiva con fecha compromiso.
- Realizar una revisión de seguimiento con SecureAudit Solutions S.L. a las 4 semanas para verificar el estado de los hallazgos críticos y altos.
- Llevar a cabo una re-auditoría parcial a los 6 meses para verificar la efectividad de todas las medidas implementadas.
- Considerar la implantación de un programa de gestión de vulnerabilidades continuo para mantener el nivel de seguridad a lo largo del tiempo.

8. Glosario

Término	Definición
CVE	Common Vulnerabilities and Exposures: listado público de vulnerabilidades de seguridad conocidas con identificador único.
CWE	Common Weakness Enumeration: lista de tipos de debilidades de software para desarrolladores y profesionales de seguridad.
CVSS	Common Vulnerability Scoring System: sistema estándar de puntuación de la gravedad de vulnerabilidades (escala 0–10).
IDOR	Insecure Direct Object Reference: vulnerabilidad web que permite acceder a recursos de otros usuarios modificando parámetros.
MitM	Man-in-the-Middle: ataque en el que el atacante se interpone en la comunicación entre dos partes sin que ninguna lo detecte.
NDA	Non-Disclosure Agreement: acuerdo de confidencialidad legalmente vinculante entre dos partes.
OSCP	Offensive Security Certified Professional: certificación avanzada de penetration testing de Offensive Security.
OSSTMM	Open Source Security Testing Methodology Manual: metodología abierta para pruebas de seguridad operacional.
OWASP	Open Web Application Security Project: organización que publica estándares y guías de seguridad para aplicaciones web y móviles.
OWISAM	Open Wireless Security Assessment Methodology: metodología para la auditoría de redes inalámbricas.
Pentest	Prueba de penetración: ataque controlado y ético a un sistema para encontrar y explotar vulnerabilidades reales.
RGPD	Reglamento General de Protección de Datos (UE 2016/679): normativa europea de protección de datos personales.
Salt	Valor aleatorio añadido a una contraseña antes del hash para prevenir ataques de tablas rainbow.
WPA2-Enterprise	Variante de WPA2 que usa servidor RADIUS para autenticar individualmente a cada usuario, sin contraseña compartida.